

ThreatConnect – Indicator Threat & Confidence Ratings

Corso: Cybersecurity Analyst

Modulo: W19D1 (Pratica)

Piattaforma: Epicode

Studente: Nouman Javed Nizami

Data: 27/04/2026

Introduction

ThreatConnect uses two key dimensions to evaluate indicators: Threat Rating (0–5) and Confidence Rating (0–100). These represent the maliciousness level and the reliability of the information.

Threat Rating (0–5)

- 0 – Unknown: Not enough information to assess.
- 1 – Suspicious: Suspicious activity, not confirmed.
- 2 – Low Threat: Opportunistic attacker, pre-attack phase.
- 3 – Moderate Threat: Basic attacker, active intrusion.
- 4 – High Threat: Advanced attacker, persistent activity.
- 5 – Critical Threat: Highly sophisticated attacker, critical threat.

Threat Factors

- Capability
- Determination
- Progression (Cyber Kill Chain)

Confidence Rating (0–100)

- 0 – Unassessed: Not evaluated
- 1 – Discredited: False information
- 2–29 – Improbable: Contradicted
- 30–49 – Doubtful: Possible but weak
- 50–69 – Possible: Partially consistent
- 70–89 – Probable: Logical and consistent
- 90–100 – Confirmed: Verified by independent sources

Confidence Factors

- Independent confirmation
- Plausibility

- Consistency

Conclusion

Separating Threat and Confidence enables better decision-making in cyber threat intelligence operations.

Cyber Threat Intelligence Report

Introduction

This report provides an advanced analysis of common cyber threats affecting organizations, aligned with SOC operations and GRC (Governance, Risk, and Compliance) frameworks. It includes threat descriptions, attack vectors, business impact, risk evaluation, MITRE ATT&CK mapping, and security controls aligned with ISO 27001 and NIST.

Phishing

Phishing is a social engineering attack where adversaries impersonate trusted entities to steal credentials or sensitive data. Common vectors include email, fake login pages, and SMS (smishing). MITRE ATT&CK: Initial Access (T1566).

Risk Assessment

Likelihood: High | Impact: High → Risk Level: Critical

Security Controls (ISO 27001 / NIST)

ISO 27001: A.7.2.2 (Security Awareness), A.9 (Access Control)

NIST: PR.AT (Awareness Training), PR.AC (Access Control)

Mitigation Strategies

Implement security awareness training, phishing simulations, email filtering, MFA enforcement, and URL protection.

Malware

Malware includes trojans, spyware, and worms used to compromise systems. Delivered via downloads, attachments, or exploits. MITRE ATT&CK: Execution (T1204), Persistence (T1547).

Risk Assessment

Likelihood: High | Impact: High → Risk Level: Critical

Security Controls (ISO 27001 / NIST)

ISO 27001: A.12.2 (Malware Protection), A.13 (Network Security)

NIST: PR.IP (Protection Processes), DE.CM (Detection)

Mitigation Strategies

Deploy endpoint protection (EDR), patch management, application whitelisting, and network segmentation.

Ransomware

Ransomware encrypts organizational data and demands payment. Often enters via phishing or vulnerabilities. MITRE ATT&CK: Impact (T1486).

Risk Assessment

Likelihood: High | Impact: Very High → Risk Level: Critical

Security Controls (ISO 27001 / NIST)

ISO 27001: A.12.3 (Backup), A.16 (Incident Management)

NIST: PR.DS (Data Security), RS.RP (Response Planning)

Mitigation Strategies

Maintain offline backups, apply patching, restrict privileges, implement EDR, and incident response plans.

DDoS (Distributed Denial of Service)

DDoS attacks flood systems with traffic using botnets, causing service disruption. MITRE

ATT&CK: Impact (T1498).

Risk Assessment

Likelihood: Medium | Impact: High → Risk Level: High

Security Controls (ISO 27001 / NIST)

ISO 27001: A.13 (Network Security)

NIST: PR.PT (Protective Technology), DE.AE (Anomalies Detection)

Mitigation Strategies

Use traffic filtering, rate limiting, CDN/WAF, and DDoS protection services.

Data Breach

A data breach involves unauthorized access to sensitive data through compromised credentials or vulnerabilities. MITRE ATT&CK: Exfiltration (T1041).

Risk Assessment

Likelihood: Medium | Impact: Very High → Risk Level: Critical

Security Controls (ISO 27001 / NIST)

ISO 27001: A.8 (Asset Management), A.18 (Compliance)

NIST: PR.DS (Data Security), ID.RA (Risk Assessment)

Mitigation Strategies

Implement encryption, access control, monitoring, DLP solutions, and regular audits.

Conclusion

This advanced threat analysis demonstrates the importance of integrating threat intelligence with risk management frameworks. Combining SOC monitoring with GRC controls enables organizations to reduce risk exposure and respond effectively to cyber threats.

Cyber Threat Analysis & Mitigation Report

OWASP Top 10 – MITRE ATT&CK

Mapping

Cross-Site Scripting (XSS)

Risk Level

Likelihood: High | Impact: Medium-High → Risk: High

OWASP Top 10

A03:2021 – Injection

MITRE ATT&CK

Tactic: TA0001 – Initial Access

Technique: T1659 – Content Injection

Mitigations (MITRE)

M1041 – Encrypt Sensitive Information

M1021 – Restrict Web-Based Content

M1036 – Account Use Policies (limit session abuse)

Technical Explanation (SOC Perspective)

XSS occurs when user input is not sanitized and is executed in the browser of another user. From a SOC perspective, this may appear as abnormal session behavior or multiple logins from different locations. Attackers exploit this to steal cookies (session hijacking) and impersonate users.

Scenario 2 – SQL Injection

Risk Level

Likelihood: High | Impact: Very High → Risk: Critical

OWASP Top 10

A03:2021 – Injection

MITRE ATT&CK

Tactic: TA0001 – Initial Access

Technique: T1190 – Exploit Public-Facing Application

Mitigations (MITRE)

M1048 – Application Isolation

M1050 – Exploit Protection (WAF)

M1030 – Network Segmentation

M1026 – Privileged Account Management

Technical Explanation (SOC Perspective)

SQL Injection allows attackers to manipulate backend queries. In SOC monitoring, this can be detected through abnormal query patterns or database logs. The attack can lead to full database compromise, data exfiltration, and privilege escalation.

Scenario 3 – Insecure Deserialization

Risk Level

Likelihood: Medium | Impact: Very High → Risk: Critical

OWASP Top 10

A08:2021 – Software and Data Integrity Failures

MITRE ATT&CK

Tactic: TA0002 – Execution

Technique: T1203 – Exploitation for Client Execution

Mitigations (MITRE)

M1026 – Privileged Account Management

M1051 – Update Software

M1016 – Vulnerability Scanning

M1040 – Behavior Prevention on Endpoint

Technical Explanation (SOC Perspective)

Insecure deserialization allows attackers to send malicious objects that execute code during processing. In a SOC, this may be detected via unusual process execution or endpoint alerts. This vulnerability often leads to Remote Code Execution (RCE), giving attackers full control of the system.